CONFIDENTIAL SECURITY DOCUMENT

Compliance Gap Assessment Report

Example Corp — PCI-DSS v4.0 Gap Assessment

Control-by-control gap analysis

Document Type	Compliance / regulatory framework gap assessment
Framework	[FILL: e.g. PCI-DSS v4.0]
Assessment Date	1 January 2030
Controls Assessed	[FILL: N]
Overall Compliance	PARTIAL
Classification	**Confidential — Restricted Distribution**

Distribution: This document contains sensitive compliance information and must not be shared outside authorised personnel responsible for remediation.

Scope of analysis: [FILL: One or two sentences on assessment method, e.g. "a control-by-control gap assessment against <framework>, based on document review, configuration review, and personnel interviews. This is a readiness assessment, not a certification audit."]

1

1 Table of Contents 1

2 Executive Summary 2
2.1 Overview . . . 2
2.2 Overall Compliance Status . . . 2
2.3 Compliance by Control Domain . . . 2

3 Scope & Methodology 3
3.1 Framework & Scope . . . 3
3.2 Approach . . . 3
3.3 Status Definitions . . . 3

4 Control Domain Assessment 4
4.1 [FILL: Domain 1, e.g. "Access Control"] . . . 4
4.2 [FILL: Domain 2, e.g. "Data Protection"] . . . 4

5 Consolidated Gap Register 5

6 Remediation Roadmap 6

7 Appendix A — Evidence Index 7

8 Appendix B — Interviewees 7

2 Executive Summary

Overview

A control-by-control gap assessment of Example Corp — PCI-DSS v4.0 Gap Assessment was conducted against [FILL: framework name and version]. [FILL: One or two sentences on the overall readiness posture.]

CRITICAL — Key Takeaway

Result — [FILL: one-line verdict, e.g. "the organisation is not currently ready for a formal audit; N critical gaps must close first"].

Headline conclusions:

- [FILL: Headline gap 1]
- [FILL: Headline gap 2]

Overall Compliance Status

PARTIALLY COMPLIANT

Compliance by Control Domain

Domain	% Compliant	Status
[FILL: e.g. Access Control]	[FILL: n%]	PARTIAL
[FILL: e.g. Data Protection]	[FILL: n%]	NON-COMPLIANT
[FILL: e.g. Logging & Monitoring]	[FILL: n%]	COMPLIANT

3 Scope & Methodology

Framework & Scope

Item	Detail
Framework	[FILL: e.g. PCI-DSS v4.0 / ISO 27001:2022 / SOC 2 Type II (Trust Services Criteria)]
Environment(s) in scope	[FILL: systems, business units, or a cardholder-data-environment boundary]
Assessment type	Readiness gap assessment (not a certification/attestation audit)

Approach

1. **Document review.** Policies, standards, and procedures reviewed against each control requirement.
2. **Configuration/technical review.** Sampled systems checked for technical control implementation (e.g. encryption, logging, access control lists).
3. **Interviews.** Control owners interviewed to confirm processes are followed in practice, not just documented.
4. **Gap rating.** Each control rated Compliant / Partial / Non-Compliant / Not Applicable, with evidence referenced.

Status Definitions

Status	Definition
COMPLIANT	Control is fully implemented and evidenced.
PARTIAL	Control is partially implemented, or implemented but not consistently evidenced.
NON-COMPLIANT	Control is not implemented.
N/A	Control does not apply to this environment (with justification on file).

4 Control Domain Assessment

[FILL: Domain 1, e.g. "Access Control"]

Control ID	Requirement	Status	Evidence / Gap
[FILL: e.g. 7.1]	[FILL: Restrict access to cardholder data by business need to know]	COMPLIANT	[FILL: Evidence reference]
[FILL: e.g. 8.3]	[FILL: Multi-factor authentication for all access into the CDE]	PARTIAL	[FILL: Gap: MFA not enforced for one admin group]

[FILL: Domain 2, e.g. "Data Protection"]

Control ID	Requirement	Status	Evidence / Gap
[FILL: e.g. 3.5]	[FILL: Protect stored account data with strong cryptography]	NON-COMPLIANT	[FILL: Gap: field-level encryption not implemented]

5 Consolidated Gap Register

Control ID	Domain	Gap	Priority
[FILL: 8.3]	[FILL: Access Control]	[FILL: MFA not enforced for one admin group]	HIGH
[FILL: 3.5]	[FILL: Data Protection]	[FILL: Field-level encryption not implemented]	CRITICAL

6 Remediation Roadmap

Priority	Action	Target Date
P1	[FILL: e.g. Implement field-level encryption for stored account data]	[FILL: date]
P2	[FILL: e.g. Enforce MFA for the remaining admin group]	[FILL: date]
P3	[FILL: e.g. Formalise the access-review process in writing]	[FILL: date]

[FILL: Optional note on recommended timeline to formal audit readiness given the roadmap above.]

7 Appendix A — Evidence Index

Evidence Ref	Description
[FILL: EV-01]	[FILL: e.g. Access control policy document, v3, dated ...]
[FILL: EV-02]	[FILL: e.g. Screenshot of MFA enforcement configuration]

8 Appendix B — Interviewees

- [FILL: Role - e.g. Head of IT Operations]